Student Lab Guide

Setup

All datasets for the day come in one download, `SIEM_Starter_labs.zip` (17 MB zipped, about 500 MB unpacked), including the APT29 Day 1 data for Level 3.

```
mkdir -p ~/siem-labs && cd ~/siem-labs
wget https://github.com/Healthy-byte/training/raw/main/SIEM_Starter_labs.zip


unzip SIEM_Starter_labs.zip

# Level 1: the lab folder holds one .json file. Go to the lab's folder and set F:

cd ~/siem-labs/SIEM_Starter_labs/Level1_net_localgroup
F=$(ls *.json)
jq -c . "$F" | head -1      # first event, to check that it works
```

Where a hint says `FILE`, use `"$F"`. Level 2 sets its own file names at the top of each lab.

Lab	Folder in `SIEM_Starter_labs/`	Records	Hosts
1	`Level1_net_localgroup/`	884	3
2	`Level2B_host_and_network/`	53,698 host events + 261 Zeek records	1
2 stretch (optional)	`Level2A_zeek_apt29_day2/`	5,664 Zeek records	5 internal IPs
3 (APT29)	`Level3_apt29_day1/`	196,081	4

Level 1: Foundations

Scenario. A help-desk ticket says a PowerShell window flashed on WORKSTATION5 in the THESHIRE domain. You get 36 seconds of logs from three hosts. Learn to read the raw events and say what happened in two sentences.

Goal: know what a JSON event looks like, count and filter it, read a process-creation event, and decode a Base64 command safely.

Dataset: `Level1_net_localgroup/`

#	Task	Hint
1.1	How many events are in the file? Give the first and last `@timestamp`.	`wc -l` `jq -r '."@timestamp"' FILE | sort`
1.2	List the hosts with their event counts. Which one is the domain controller, and how can you tell?	`jq -r .Hostname | sort | uniq -c`; look at the names and channels
1.3	Which three `Channel` + `EventID` pairs are most common? What does the top one record?	Sysmon event ID reference
1.4	Find every process creation (Sysmon EventID 1). How many are there? Which command ran, on which host and as which user?	`select(.EventID==1)`
1.5	One command produced two process events. Why?	Compare `Image` and `ParentImage` of both
1.6	What started the first process? Explain what each of its flags does and why this pattern is suspicious.	`ParentCommandLine`
1.7	Decode the Base64 string as text. What is the first thing the script tries to turn off? Why does this matter for you as a defender?	`base64 -d`
1.8	Which Security event shows that the group was read? Give the time, the group and the calling process.	Security EventID 4799
1.9	Name the MITRE ATT&CK technique ID for what the attacker was doing.	attack.mitre.org

Wrap-up: write an alert a manager can read:

what happened, on which host, and what actions to take.

Level 2: Host meets network

Most SOCs pair host logs with network metadata from a sensor such as Zeek. The network shows who talked to whom, the host shows which program and which account did it. In Lab 2 you join the two. Finished early? Try the stretch lab at the end.

Zeek basics:

- `conn.log` has one record per connection: the client (`id.orig_h`, `id.orig_p`), the server (`id.resp_h`, `id.resp_p`), the duration and the bytes.
- `http`, `ssl`, `x509` and the other logs add protocol detail for the same connections.
- `ts` is Unix time in seconds. Convert it with `todate`.
- In Lab 2 the field names contain dots, so `jq` needs them in quotes: `."id.resp_h"`.

Lab 2: The download that phoned home

Scenario. The network team escalates a Zeek alert: workstation MKT01 (`192.168.1.41`) in the `pandalab.com` domain downloaded an EXE over plain HTTP from `10.0.5.13`, then opened encrypted sessions to the same server on port 8080. Zeek sees the traffic but not who made it. You get the Zeek logs and MKT01's own Windows logs for the same few minutes. Find out who downloaded the file, who ran it and what it did.

Goal: read a Zeek connection, find the program behind it on the host by matching the source port, and follow that program to the end of the attack.

Dataset: `Level2B_host_and_network/`, with `zeek/` (12 logs, 261 records) and `host/MKT01_windows_events.json` (53,698 Windows events). Any tool is fine. The hints are fragments for `jq`.

The Query cookbook tab has a Lab 2 section that shows how to count values and how to find every event with a given port.

One thing to know: the clocks don't agree. Zeek's `ts` is about 19 hours ahead of the host's `@timestamp`. So match a connection on its port, not on its time.

```
cd ~/siem-labs/SIEM_Starter_labs/Level2B_host_and_network
H=host/MKT01_windows_events.json
Z=zeek
jq -c . "$Z/conn.log" | head -1      # first Zeek record, to check that it works
```

#	Task	Hint
2.1	Start with the network. How many connections did MKT01 make to `10.0.5.13`, and on which ports?	`select(."id.resp_h"=="10.0.5.13")`, then count `."id.resp_p"`
2.2	Port 80 is plain HTTP, so Zeek saw what came back. Which file did the server send? Give its type and size.	In `http.log`: `resp_mime_types`, `response_body_len`
2.3	Port 8080 is encrypted, so Zeek can't read it, but it records	In `x509.log`:

#	Task	Hint
	the server's certificate. Who issued the certificate, and why is that suspicious?	`."certificate.subject"`, `."certificate.issuer"`
2.4	Now switch to the host. Sysmon 3 logs every connection together with the program that made it. Which programs talked to `10.0.5.13`, on which port, and as which user? Check that one `SourcePort` matches an `id.orig_p` in `conn.log`.	Sysmon 3: filter on `DestinationIp`; show `SourcePort`, `Image`, `User`
2.5	Where did `winx64_payload.exe` come from? Windows tags a downloaded file with the URL it came from. Give the URL, the program that downloaded it and the folder it was saved in.	Sysmon 15: look for `HostUrl` in `Contents`
2.6	Who ran it, when, and with which integrity level? Is it the same user who downloaded it?	Sysmon 1 where `Image` contains `winx64`: `User`, `IntegrityLevel`
2.7	In 2.4 a Windows process, `svchost.exe`, also talked to the attacker. Why? Find the event that links it to the payload.	Sysmon 8 (one process starts a thread inside another): `SourceImage` → `TargetImage`
2.8	What did that `svchost.exe` (PID 1400) do one minute later? Name the MITRE ATT&CK technique.	Sysmon 10 (one process opens another) where `SourceProcessId` is `"1400"`: `TargetImage`, `GrantedAccess`

Wrap-up: write an alert a manager can read.

What happened on MKT01, and what actions to take.

Stretch lab (optional): Spot the beacon

Scenario. A different network, from the APT29 evaluation (Day 2), and this time there are no host logs. A Zeek sensor recorded 32 minutes of traffic from workstation `10.0.1.5`. One of its destinations is the attacker's command-and-control (C2) server. Find it from the network alone, and show that the other external servers are harmless.

Dataset: `Level2A_zeek_apt29_day2/` (5,664 records). All Zeek logs are in one file, the `@stream` field says which log a record came from.

#	Task	Hint
2S.1	Which destination did `10.0.1.5` contact most often? How many connections, from when to when, and about how many seconds apart on average?	`select(."@stream"=="conn" and .id_orig_h=="10.0.1.5")`, then count `id_resp_h` and `id_resp_p` first and last `ts` with `todate`
2S.2	Compare the certificates. Which one is self-signed (subject and issuer are the same)?	`@stream x509`: `certificate_subject`, `certificate_issuer`
2S.3	Which server names did the TLS sessions ask for? Which destination never sends a name, and why does that fit C2?	`@stream ssl`: `id_resp_h`, `server_name`